

UNIT – I

THE NEED FOR INFORMATION SYSTEM SECURITY COMPLIANCE

1. Introduction to Information Systems Security Compliance

Modern organizations depend heavily on information systems to run business operations, store data, and maintain service availability. With this dependency comes **risk** — threats, vulnerabilities, misuse, data breaches, and regulatory liabilities.

Because of this, IT security is no longer optional. It is tied directly to:

- Legal mandates
- Industry regulations
- Governance requirements
- Risk management frameworks
- Business survival and reputational stability

According to the textbook introduction, compliance is critical because IT systems are now integrated into business workflows and attackers increasingly exploit weak controls. Therefore, regular **assessments** and **audits** exist to verify the presence and effectiveness of controls.

2. What Is an IT Security Assessment?

A **security assessment** is a structured evaluation of the security posture of information systems to determine:

- What risks exist
- Which controls are implemented
- Whether the controls work effectively
- What gaps or vulnerabilities remain

The goal is **not** to punish but to **detect weaknesses**, support risk decisions, and improve security posture.

The book defines assessment as a **risk-based security evaluation process**, involving:

- Categorizing information systems
- Selecting appropriate controls
- Assessing the effectiveness of controls
- Monitoring and updating controls continuously

2.1 Key Outcomes of a Security Assessment

A proper assessment helps the organization:

1. Identify security weaknesses
 2. Confirm previously remediated vulnerabilities
 3. Prioritize mitigation actions
 4. Provide assurance that risks are accepted appropriately
 5. Support budgeting and resource allocations
-

3. Methods of Conducting Security Assessments

NIST SP 800-53A defines three primary assessment methods:

3.1 Examination

Reviewing documentation, system configurations, policies, logs, network diagrams, etc., to verify:

- Policies exist
- Controls are implemented
- Controls are documented

3.2 Interview

Speaking with:

- System owners
- Administrators
- Security teams
- End users

Purpose: validate how controls are implemented and whether processes match documented procedures.

3.3 Testing

Testing technical configurations:

- Penetration testing
- Vulnerability scanning
- Configuration testing
- Credential testing
- Logon failure threshold testing

Testing validates whether controls **behave as expected** under real conditions.

4. Example: Failed Logon Attempt Control Assessment

The book gives a detailed example:

Control: Lock account after *four invalid logon attempts* within 15 minutes and enforce lockout periods.

Assessment Objectives include verifying thresholds and lockout duration.

Assessment Methods include examining configs, logs, and performing live tests.

This illustrates the structured, evidence-based nature of assessments.

5. Types of Security Assessments

Organizations may conduct:

- Network architecture reviews
- Security policy reviews
- Vulnerability assessments
- Physical security assessments
- Security risk assessments
- Application assessments

- Social engineering assessments
- Penetration tests

Penetration Tests

Simulate attacker behavior under controlled conditions to:

- Discover weaknesses
- Measure exploitability
- Demonstrate real attack paths

Pen tests can be:

- **Black-box:** No prior knowledge
 - **White-box:** Full internal knowledge
 - **Gray-box:** Partial knowledge
-

6. What Is an IT Security Audit?

An **IT security audit** is a **formal, independent, structured evaluation** of internal controls, policies, processes, and compliance obligations.

It provides **reasonable assurance** that IT controls are:

- Implemented
- Effective
- Compliant with laws and standards

The audit is independent and follows strict methodologies.

The book states:

“An IT security audit is an independent assessment of internal policies, controls, and activities.”

7. Types of Audits

7.1 Financial Audit

Verifies correctness of financial statements.

7.2 Compliance Audit

Determines whether the organization follows laws, regulations, or industry standards.

7.3 Operational Audit

Reviews operational processes, procedures, and departmental controls.

7.4 Investigative Audit

Triggered by suspicious activity or wrongdoing.

7.5 IT Audit

Examines:

- IT governance
- IT infrastructure
- Applications
- Security controls
- Data communications

Modern organizations often perform **integrated audits** combining financial + operational + IT because systems overlap.

8. Scope of IT Security Audits

Scope may include:

8.1 Organizational Controls

Management structure, governance, policies, risk management.

8.2 Compliance Controls

Whether the organization meets:

- SOX
- HIPAA

- PCI DSS
- GDPR
- Local laws

8.3 Application Controls

Change management, input validation, authorization, audit logging.

8.4 Technical Controls

Firewalls, routers, servers, encryption, OS hardening, patching.

9. External vs. Internal Auditors

External Auditors

- Independent organizations
- Required for publicly traded companies
- Often the “Big Four” (PwC, KPMG, EY, Deloitte)
- Cannot provide consulting + auditing simultaneously

Internal Auditors

- Employees or outsourced internal audit teams

- Report to Board Audit Committee
 - Can give recommendations but cannot design/implement systems
-

10. How Does an Audit Differ from an Assessment?

(Aligned to book content in Chapter 1)

An **audit** and an **assessment** evaluate controls, but they differ in purpose, structure, rigor, and consequences.

The book explains that although they share similarities, **assessments are improvement-oriented**, while **audits are compliance-verification activities with consequences**.

10.1 Key Differences (Book-Aligned)

1. Purpose

Audit	Assessment
Measures compliance with regulations, policies, standards	Measures security posture and identifies weaknesses
Determines pass/fail	Offers recommendations; no pass/fail
Ensures controls exist & are effective	Suggests improvements, risk mitigation

2. Independence

- **Audits must be independent** — auditors cannot audit systems they designed or implemented.
 - Assessments **may be performed internally** or by external consultants.
-

3. Rigor

- Audits follow **formal methodologies**, established principles, and strict documentation trails.
- Assessments can be **flexible**, tailored, and informal.

4. Focus

- **Audit:** Looks at **past performance** and compliance history.
 - **Assessment:** Evaluates **current state** and expected performance.
-

5. Consequences

- Audit results may lead to:
 - Compliance certification
 - Penalties
 - Required remediation
 - Assessments do **not** produce certifications and have **no penalties**.
-

Example (Non–case study):

If password policy is evaluated:

- **Audit** will check whether the policy is implemented *exactly as written* (e.g., password length = 12).
 - **Assessment** will check whether the policy is *effective* and whether improvements are needed (e.g., recommending MFA).
-

11. Why Are Governance and Compliance Important?

The book emphasizes that **without governance**, risk management and compliance **cannot function effectively** because IT is deeply integrated into business operations.

11.1 Governance Ensures:

- Policies and procedures are defined and followed
- Risks are identified, analyzed, and mitigated
- IT supports business goals

- Controls are monitored and updated
- Management accountability exists

Because organizations depend heavily on IT systems, a failure in governance directly results in failure of:

- Service availability
 - Data confidentiality
 - Financial accuracy
 - Operational integrity
-

11.2 Compliance Ensures:

- Protection of business & consumer privacy data
- Alignment with external laws and standards
- Trust with stakeholders
- Avoidance of fines and penalties
- Reduction of security breaches

Compliance is linked to **both**:

✓ Risk Management

Ensures risks are reduced through effective controls.

✓ Governance

Ensures controls and decisions align with business and regulatory needs.

12. What Happens If an Organization Does Not Comply with Compliance Laws?

The book clearly outlines penalties and consequences.

12.1 Legal Consequences

- Fines

- Penalties from regulatory bodies
 - Possible imprisonment (in cases of proven intent)
-

12.2 Financial Consequences

Organizations face:

- Increased operational costs
 - Costs related to fixing noncompliance
 - Investigation and audit expenses
 - Increased insurance and capital costs
-

12.3 Operational Consequences

Noncompliance can cause:

- Service interruptions
- Loss of access to certain business services
- Forced process changes
- Regulatory-imposed restrictions

Example:

If an organization fails to meet a payment security requirement (PCI DSS), the card processors may restrict or revoke transaction privileges.

12.4 Reputational Damage

Noncompliance can lead to:

- Loss of customer trust
- Loss of market competitiveness
- Damage to brand image
- Reduced shareholder confidence

Even if an organization survives financially, **trust restoration** takes years.

13. What Is the Scope of an IT Compliance Audit?

(Strictly based on book Chapter 3 introduction; no case studies)

The scope determines **what is audited, why, and to what depth.**

13.1 Core Components of Scope

According to the book, IT audits normally cover:

1. Organizational Compliance Requirements

Evaluating whether the organization meets:

- Internal policies
 - Standards
 - External regulations
-

2. Protection of Privacy Data

Audit ensures controls protect:

- Customer data
 - Employee data
 - Business-sensitive data
-

3. Security Controls

Audit verifies:

- Correct controls exist
 - Controls work effectively
 - Controls meet regulatory expectations
-

4. Infrastructure Domains

The book describes **seven domains** of a typical IT infrastructure that must be audited:

1. **User Domain**
2. **Workstation Domain**
3. **LAN Domain**
4. **LAN-to-WAN Domain**
5. **WAN Domain**
6. **Remote Access Domain**
7. **System/Application Domain**

The audit scope includes all controls, risks, and compliance requirements in each domain.

13.2 Maintaining IT Compliance (Summary of Book Content)

Maintaining compliance requires:

A. Periodic Security Assessments

Performed regularly to detect gaps early.

B. Annual Compliance Audit

Independent audit verifying adherence to regulations.

C. Defined Security Controls

Controls must be:

- Documented
- Implemented
- Monitored
- Reviewed regularly

The book stresses that compliance is **ongoing**, not a one-time achievement.

14. What Does an Organization Need To Do To Be in Compliance?

(Aligned with Chapter 3 introduction of the book)

Compliance is not a single activity—it is a **continuous process**. To remain compliant, an organization must implement structured steps that ensure policies, controls, and procedures always meet regulatory requirements.

14.1 Steps to Achieve Compliance

1. Understand Applicable Regulations

Organizations must identify which laws, frameworks, standards, and policies apply.

Examples:

- If processing payment cards → PCI DSS applies
- If handling health information → HIPAA applies
- If operating in India → IT Act, CERT-In guidelines apply

This step is mandatory before any audit begins.

2. Implement Proper Security Controls

Controls must:

- Protect data confidentiality, integrity, availability
- Align with internal policies
- Support external laws and industry standards

Examples of required controls:

- Password policies
 - Network segmentation
 - Encryption
 - Logging and monitoring
 - Access controls
-

3. Protect Privacy Data

The book emphasizes that protecting sensitive data is a **primary requirement** of IT compliance. This includes:

- Customer data
- Employee personal data
- Financial data
- Business confidential information

Compliance requires identifying where data resides and protecting it at:

- Storage
 - Processing
 - Transmission
 - Backup
-

4. Document All Policies and Procedures

Documentation must include:

- Security policies
- Standards
- Operating procedures
- Guidelines
- Network diagrams
- Change management records
- Configuration baselines

Documentation is critical because **auditors verify compliance through documentation first.**

5. Train Employees and Maintain Awareness

People are often the weakest link. Compliance requires proactive:

- Awareness programs
- Training on policies
- Acceptable use policies
- Role-based training

Example:

Employees must be trained not to share passwords or bypass security mechanisms.

6. Conduct Regular Security Assessments

Assessments identify:

- Weak controls
- Noncompliance areas
- Misconfigurations
- New risks

This helps prepare for official audits and reduces audit failure risk.

7. Perform Annual Compliance Audits

A formal audit must be done at least once a year by qualified personnel to ensure:

- Controls exist
 - Controls are functioning
 - Processes match documentation
 - Requirements are met
-

15. What Are You Auditing Within the IT Infrastructure?

According to the book, an IT compliance audit must evaluate **all critical domains** of the IT environment. Each domain contains unique assets, users, risks, and controls.

(A detailed domain-by-domain audit is part of Unit II & III; here we introduce the concept as per Unit I.)

15.1 High-Level Audit Areas

1. User Domain

Here auditors check:

- User access rights
- Role-based access control
- Password policies
- User onboarding/offboarding
- Privilege misuse

Example:

Verifying whether employees only have the permissions necessary for their job roles.

2. Workstation Domain

Auditors inspect:

- Endpoint configurations
- Patch levels
- Antivirus status
- Local access rights

Example:

Checking if USB ports are restricted to prevent data leakage.

3. LAN Domain

Focus areas include:

- Switch configurations
- VLAN segregation
- Firewall placement inside LAN
- Network access control

Example:

Ensuring servers and employee desktops are separated using VLANs.

4. LAN-to-WAN Domain

This is the **enterprise boundary**. Audit includes:

- Firewalls
- Routers
- IDS/IPS
- Proxy servers
- DMZ

Example:

Verifying firewall rules follow “deny-by-default” principle.

5. WAN Domain

Covers organizational connectivity to ISPs or branch offices.

Audit checks:

- Routing security
 - WAN encryption
 - Redundancy
 - Service-level compliance
-

6. Remote Access Domain

Audit checks:

- VPN access
- Authentication methods
- Endpoint security for remote users
- Monitoring of remote sessions

Example:

Ensuring MFA is used for VPN logins.

7. System/Application Domain

Covers data centers, servers, applications, and databases.

Audit checks:

- Application security controls
- Change management
- Patch levels
- Backup and recovery
- Access control to critical servers

Example:

Verifying that admin access to application servers is logged and monitored.

16. Maintaining IT Compliance

Compliance does not end after one audit; it must be **maintained continuously**.

The book describes compliance as an **ongoing cycle** requiring monitoring, updates, and reassessment.

16.1 Components of Ongoing Compliance Management**1. Periodic Security Assessments**

These help detect new vulnerabilities, changes, and misconfigurations before they impact compliance.

Frequency:

- Monthly (for high-risk systems)
- Quarterly
- Semi-annual

2. Annual Compliance Audit

A formal requirement.

Verifies and certifies whether the organization meets applicable laws and standards.

3. Continuous Monitoring

Includes:

- Log monitoring
- Network monitoring
- Intrusion detection
- Alerting systems

Monitoring ensures threats are detected early.

4. Updating Policies and Controls

Policies must evolve based on:

- New regulations
- New threats
- Technology changes
- Audit findings

Example:

If new ransomware attacks emerge, policies may require mandatory offline backups.

5. Corrective Actions

Compliance audits and assessments identify gaps.

Maintaining compliance requires:

- Documenting findings
- Assigning corrective tasks

- Closing gaps
 - Verifying remediation
-

6. Management Review and Governance

Senior leadership must:

- Approve policies
- Review audit reports
- Allocate resources
- Support compliance initiatives

Governance is essential for successful long-term compliance.

17. Example: Lifecycle of Maintaining IT Compliance (No case study)

A practical, syllabus-aligned example:

Step 1 — Identify Regulation

PCI DSS applies because the company processes credit cards.

Step 2 — Implement Controls

Encryption, logging, file integrity monitoring, network segmentation.

Step 3 — Train Employees

Security awareness and data handling procedures.

Step 4 — Conduct Assessments

Quarterly vulnerability scans.

Step 5 — Annual Audit

A Qualified Security Assessor validates compliance.

Step 6 — Maintain and Improve

When new threats arise, additional logs or monitoring tools may be added.

This reflects the **continuous nature** of compliance.

18. Seven Domains of a Typical IT Infrastructure

(from Chapter 3 overview – Weiss & Solomon)

The seven domains are:

1. **User Domain**
2. **Workstation Domain**
3. **LAN Domain**
4. **LAN-to-WAN Domain**
5. **WAN Domain**
6. **Remote Access Domain**
7. **System / Application Domain**

Each must be checked during compliance audits.

19. User Domain

This domain includes **people who access systems**: employees, contractors, vendors.

19.1 What auditors check (book-aligned)

1. User Authentication & Authorization

- Password policies
- MFA requirements
- Account creation, modification, deletion
- Unique user IDs

2. Access Controls

- Role-based access (RBAC)
- Segregation of duties
- Least privilege

3. Acceptable Use Policies

Ensuring users sign and acknowledge security policies.

4. Training & Awareness

Employees must understand:

- Data handling
- Acceptable use
- Threats like phishing

19.2 Example

Auditor checks whether a terminated employee's account was disabled within the required time frame.

20. Workstation Domain

Includes laptops, desktops, tablets, mobile devices.

20.1 What auditors check

1. Configuration Hardening

- Disable unnecessary services
- Local firewall enabled
- Secure boot

2. Patch & Update Management

- Operating system updates
- Application patches
- Automated patch deployment systems

3. Anti-Malware Protection

- Antivirus installed
- Signatures updated
- Real-time protection enabled

4. Device & Port Control

- USB port control
- Disk encryption (BitLocker, FileVault, etc.)
- Restrictions on installing unauthorized software

20.2 Example

Checking if USB mass storage devices are blocked to reduce data leakage risk.

21. LAN Domain

Local Area Network inside organizational boundaries.

21.1 What auditors check

1. Switch Configuration

- VLAN segmentation
- Port security
- MAC address filtering

2. Network Access Control

- 802.1X authentication
- Guest networks separated
- Internal traffic monitored

3. LAN Security Policies

Clear documentation for:

- IP addressing schema
- Naming conventions
- Network diagrams

4. Monitoring & Logging

Tools for:

- Packet analysis
- Network traffic monitoring

21.2 Example

Auditor ensures sensitive servers are separated from end-user networks via VLANs.

22. LAN-to-WAN Domain

This is the boundary between internal LAN and external untrusted networks (usually the Internet).

22.1 What auditors check

1. Firewalls

- Rule sets
- Change management for rules
- Deny-by-default principle

2. Intrusion Detection/Prevention Systems

- Current signatures
- Alerts monitored
- Logs reviewed regularly

3. Demilitarized Zone (DMZ) Design

Systems placed in DMZ:

- Web servers
- Public portals
- Email gateways

4. Router & Gateway Controls

- ACLs
- Routing protocols secured
- No unauthorized open ports

5. Proxy Servers / Content Filters

To block inappropriate or malicious websites.

22.2 Example

Audit checks whether firewall rule changes follow documented approval process.

23. WAN Domain

Wide Area Networks include ISP connections, MPLS links, branch office links.

23.1 What auditors check

1. WAN Encryption

- IPSec/VPN tunnels
- TLS or MPLS encryption

2. Redundancy

- Backup WAN connections
- Failover links
- SLA uptime guarantees

3. WAN Monitoring

Checking logs for:

- Bandwidth usage
- Latency issues
- Unusual traffic patterns

4. Compliance with Agreements

- ISP SOC compliance
- SLA adherence

23.2 Example

Auditor verifies that WAN failover link activates automatically during primary link failure.

24. Remote Access Domain

Includes all methods users use to connect externally to the organization.

24.1 What auditors check

1. VPN Security

- MFA for VPN authentication
- Strong encryption protocols
- Idle timeout policies

2. Endpoint Security for Remote Users

Ensuring remote devices meet:

- Patch compliance
- Antivirus status
- Device encryption requirements

3. Remote Session Monitoring

- Logging remote connections
- Alerting on suspicious access patterns

4. Configuration Management

Remote access configurations must match policies.

24.2 Example

Auditor checks that employees connecting from home use MFA and approved VPN clients.

25. System / Application Domain

This domain includes servers, databases, applications, data centers.

25.1 What auditors check

1. Server Hardening

- Secure default configurations
- Administrative access controls
- SSH hardening

2. Patch Management

- OS patching
- Application patching
- Database patching

3. Application Controls

- Input validation
- Error handling
- Logging and audit trails

4. Data Storage & Encryption

- Database encryption
- Key management
- Backup encryption

5. Change & Configuration Management

- Change requests
- Testing before deployment
- Rollback procedures

6. Backup & Recovery

Checking if:

- Backups are taken
- Stored securely
- Restored successfully during testing

25.2 Example

Auditor verifies that database containing personal data is encrypted at rest and keys are stored securely.

26. How These Domains Support Compliance

The seven domains provide auditors with a **structured framework** to examine:

- Controls
- Risks
- Processes
- Configurations
- Documentation

The structure ensures:

✓ **No part of the IT infrastructure is overlooked**

✓ **Controls are mapped to compliance requirements**

✓ **Risks are evaluated domain-by-domain**

✓ **Auditors can compare current state vs. policies and regulations**

This domain-based approach is foundational to the IT audit methodology described in the book.

27. COMPLETE UNIT-I SUMMARY (BOOK-ALIGNED)

This summary consolidates all the concepts discussed in Parts 1–4.

27.1 IT Security Assessment (Chapter 1 – Book)

An IT security assessment is a **risk-based evaluation** of IT controls to determine:

- Existing vulnerabilities
- Effectiveness of controls
- Degree of risk exposure
- Need for remediation

Assessment Methods (NIST 800-53A):

- **Examination**
- **Interview**
- **Testing**

Assessments are **improvement-focused** and **not punitive**.

27.2 IT Security Audit (Chapter 1 – Book)

An audit is an **independent, formal, structured** verification of controls and compliance.

Characteristics:

- Must be **independent**
- Follows **rigorous audit principles**
- Determines **pass/fail**
- Provides **reasonable assurance** that controls are functioning

Audits are used to verify compliance with:

- Internal policies
 - Regulations
 - Industry standards
-

27.3 Compliance

Compliance means **conforming to internal and external requirements**, including:

- Policies
- Standards
- Laws
- Regulations

General compliance cycle (based on book definition):

Interpret → Identify Gaps → Plan → Implement Controls → Monitor → Audit → Maintain

Compliance ties together:

✓ **Governance**

✓ **Risk Management**

✓ **Security Controls**

27.4 Audit vs Assessment (Book-Aligned Comparison)

Factor	Assessment	Audit
Purpose	Identify weaknesses	Verify compliance
Independence	Optional	Mandatory
Output	Recommendations	Pass/Fail
Flexibility	High	Low (rigid)
Certification	No	Yes (if passed)
Consequences	None	Possible penalties

27.5 Importance of Governance & Compliance

Governance ensures:

- Policies exist and are enforced
- Management accountability
- Proper resource allocation
- Risk-based decision-making

Compliance ensures:

- Legal adherence
 - Protection of data
 - Avoidance of penalties
 - Operational integrity
-

27.6 Consequences of Noncompliance

Noncompliance may result in:

- Fines

- Legal penalties
 - Operational restrictions
 - Reputational damage
 - Loss of trust
 - Increased cost of capital
-

27.7 What Does an Organization Do To Be in Compliance?

Steps include:

1. Identify applicable regulations
 2. Implement required controls
 3. Protect data
 4. Document policies
 5. Train employees
 6. Conduct assessments
 7. Perform annual audits
 8. Maintain & update controls
-

27.8 What Is Audited Within IT Infrastructure?

Auditors examine all **seven domains**:

1. **User Domain**
2. **Workstation Domain**
3. **LAN Domain**
4. **LAN-to-WAN Domain**
5. **WAN Domain**
6. **Remote Access Domain**
7. **System/Application Domain**

Each domain contains different assets, risks, and control points.

28. DIAGRAMS & TABLES (TEXT-BASED)

28.1 Compliance Lifecycle Diagram

Regulation Identified

↓

Interpret Requirements

↓

Gap Analysis (Assessment)

↓

Implement Controls

↓

Documentation & Training

↓

Continuous Monitoring

↓

Compliance Audit

↓

Remediation & Maintenance

28.2 Seven Domains & Primary Controls Table

Domain	What Is Audited	Examples
User Domain	Access control, authentication	RBAC, AUP
Workstation	Patch, antivirus, config	OS updates

Domain	What Is Audited	Examples
LAN	Segmentation, NAC	VLANs
LAN-to-WAN	Firewalls, IDS/IPS	ACLs
WAN	Encryption, redundancy	MPLS/VPN
Remote Access	VPN, endpoint security	MFA
System/Application Hardening, change mgmt		DB encryption

28.3 Audit vs Assessment Table (Compact)

Audit	Assessment
Independent	Internal or external
Rigid	Flexible
Past-focused	Current/future-focused
Pass/Fail	Recommendations

29. KEY DEFINITIONS (Book-Aligned)

Assessment — a structured evaluation of security controls to identify weaknesses.

Audit — an independent validation of controls and compliance.

Compliance — conforming to regulations, policies, and standards.

Governance — oversight ensuring IT aligns with business and regulatory needs.

Risk — potential for loss due to threat exploiting vulnerability.

Control — security safeguard applied to reduce risk.

Infrastructure Domain — logical boundary representing IT components.

30. EXAM-READY ANSWERS (2M, 4M, 7M, 10M)

30.1 2 MARK QUESTIONS

1. Define IT Security Assessment.

An IT security assessment is a risk-based evaluation of implemented controls to determine their effectiveness, identify weaknesses, and support remediation.

2. What is an IT Security Audit?

An audit is an independent review of policies, controls, and activities to verify compliance and provide assurance that controls function as intended.

3. What is Compliance?

Compliance is the act of adhering to internal policies and external regulations or standards.

4. What are the Seven Domains?

User, Workstation, LAN, LAN-to-WAN, WAN, Remote Access, System/Application.

30.2 4 MARK QUESTIONS

1. Differentiate between an audit and an assessment.

(Shortened table provided in section 28.3)

2. Why is governance important in compliance?

Governance ensures policy creation, risk management, accountability, alignment of IT with business, and support for compliance activities.

3. List the steps an organization must follow to achieve compliance.

Interpret regulations → identify gaps → implement controls → document → train → assess → audit → maintain.

30.3 7 MARK QUESTION

Explain the components involved in maintaining IT compliance.

- **Periodic Assessments** to detect new risks
- **Annual Audits** to verify adherence
- **Continuous Monitoring** of logs, networks, alerts

- **Updating Controls** to reflect new threats and regulations
 - **Training & Awareness** to reduce human error
 - **Documentation & Governance** to ensure ongoing accountability
 - **Corrective Actions** to close gaps
-

30.4 10 MARK QUESTION

Describe the seven domains of a typical IT infrastructure and explain what is audited in each.

Provide a structured answer:

- **User Domain** → access rights, RBAC, authentication
- **Workstation Domain** → patching, anti-malware, configuration
- **LAN Domain** → segmentation, NAC, switch security
- **LAN-to-WAN Domain** → firewalls, IDS/IPS, DMZ configuration
- **WAN Domain** → encryption, redundancy, ISP SLA compliance
- **Remote Access Domain** → VPN security, MFA, remote monitoring
- **System/Application Domain** → server hardening, change management, database security

Each domain has unique risks and control requirements essential for compliance audits.